

Reflexionsbericht - Gruppe 4

27.09.2026 - Erel, Kevin, Jonas, Andre, Nhi, Lukas

Unsere drei wichtigsten Learnings: Wir haben zu spät mit echten Kunden gesprochen, unsere Personas vom Produkt abgeleitet und die Rollen im Team zu starr verteilt.

Die drei Learnings folgen demselben Muster: Was ist passiert? Warum war das ein Problem? Was haben wir gelernt? Was machen wir konkret anders? Danach folgt eine Analyse unserer IT-Security.

1. MVP gebaut, ohne die Idee zu validieren

Was ist passiert? Wir hatten eine Idee und haben direkt ein MVP gebaut, ohne sie vorher bei potenziellen Kunden zu prüfen. Welche Value Propositions am wichtigsten sind, haben wir nicht mit Kunden bestätigt, sondern im Team selbst festgelegt. Nach weiteren Kernfunktionen haben wir ebenfalls nicht gefragt.

Warum war das ein Problem? Wir haben möglicherweise nicht in die Richtung der Features entwickelt, die Kunden wirklich brauchen. Das kostet uns nun etwas Rebuilding.

Was haben wir gelernt? Schlüsselkunden müssen wir früher befragen, bevor wir Zeit in Code stecken.

Was machen wir konkret anders? Erst Kunden befragen, dann das MVP bauen. Dafür setzen wir einen festen Checkpoint im Prozess: Die Entwicklung startet erst nach Gesprächen mit mindestens fünf potenziellen Kunden.

2. Personas kamen nach dem Produkt

Was ist passiert? Wir haben uns unser fertiges Produkt angeschaut und darauf aufbauend die Personas erstellt. Dadurch zeigen unsere Personas eher unseren Wunschkunden, aber nicht unbedingt den echten Kunden.

Warum war das ein Problem? Wenn Personas nicht den echten Kunden abbilden, verlieren sie ihren Zweck. Wir riskieren, Features zu bauen, die niemand braucht. Eigentlich sollen Personas das Produktdesign vorher steuern, nicht nachträglich bestätigen.

Was haben wir gelernt? Wir müssen früh Stakeholder kontaktieren und aus diesen Gesprächen die Personas ableiten. Dabei sollten wir weniger auf unser eigenes Produkt schauen und mehr auf die echten Menschen mit ihrem echten Bedarf.

Was machen wir konkret anders? Wie in Punkt 1: Zuerst Stakeholder ansprechen, dann Personas bauen, dann das Produkt danach ausrichten. Der Checkpoint im Prozess gilt auch hier.

3. Zu starre Rollen im Team

Was ist passiert? Wir waren sechs Leute für ein eher kleines Projekt und haben zu Beginn feste Rollen verteilt. Die Rollen brauchten aber unterschiedlich viel Zeit. Bei einigen Abgaben hatten manche Rollen viel zu tun, andere kaum etwas. Trotzdem haben wir die Arbeit nicht umverteilt, weil wir zu sehr an unseren Rollen festgehalten haben.

Warum war das ein Problem? Die Arbeitslast war im Team ungleich verteilt. Einige waren überlastet, während andere hätten helfen können.

Was haben wir gelernt? Gerade in kleinen Projekten sollten Rollen flexibler sein. Eine Rolle beschreibt, wer für etwas verantwortlich ist, aber nicht, dass nur diese Person daran arbeiten darf.

Was machen wir konkret anders? Wir verteilen die Aufgaben jede Woche neu. Rollen bleiben eine Orientierung, wir halten uns aber nur daran fest, wenn es sinnvoll ist.

4. Analyse der IT-Security

Unser Produkt verarbeitet Sprachaufnahmen und damit besonders sensible Daten. IT-Security ist für uns deshalb nicht nur ein technisches, sondern auch ein rechtliches Thema.

Wir verarbeiten Audioaufnahmen mit den Stimmen von Trainer und Teilnehmenden, die daraus erstellten Transkripte, die generierten Inhalte (Kurzschrift und Quiz) sowie die Nutzerkonten.

Bereich	Risiko	Maßnahme
Einwilligung	Teilnehmende werden aufgenommen, ohne zugestimmt zu haben.	Technischer Filter: Es wird nur die Stimme des Dozenten aufgenommen.
Speicherung	Aufnahmen und Transkripte bleiben unbegrenzt gespeichert.	Klare Löschfrist festlegen, Speicherung in der EU.
Externe KI-Dienste	Audios gehen zur Transkription an Dienste außerhalb unserer Kontrolle.	Self-hosted LLM auf eigenem Server: Die Audios verlassen unsere Infrastruktur nicht. Dadurch entfallen auch externe API-Tokens und ihre Kosten.
Zugriff	Fremde könnten Aufnahmen anderer Nutzer sehen.	Login, jeder Nutzer sieht nur seine eigenen Sessions.

Technische Umsetzung

Audioverarbeitung. Die Audioaufnahmen behandeln wir mit besonderer Sorgfalt, damit durch Benutzereingaben keine Schwachstellen entstehen. Deshalb wird jede Anfrage mit Audiodaten zuerst auf Login, CSRF-Token, Rate-Limits, Quoten und weitere Anforderungen geprüft. Auch Dateigröße und Dateityp werden vor der Verarbeitung geprüft. Die Dateien werden unter zufällig vergebenen Namen gespeichert. Der Worker, der das Audio in Text umwandelt, arbeitet isoliert: Er hat keinen Netzwerkzugang sowie eigene Prozesse und ein eigenes Dateisystem. Nach der Umwandlung wird das Audio aus Datenschutzgründen gelöscht. Bei der weiteren Verarbeitung des Textes schützen die Anweisungen, die wir dem lokalen LLM mitgeben, vor eingeschleusten Prompts (Prompt Injection). Der Output des Modells ist strukturiert und wird per Code validiert. Daten, die ans Frontend zurückgehen, werden nie als rohes HTML behandelt. Das gilt auch für alle anderen Eingabedaten.

Passwörter und Login. Passwörter speichern wir mit dem modernen, kryptografisch sicheren Verfahren Argon2 (64 MiB Speicher, 3 Durchläufe pro Hash). Passwörter müssen mindestens 12 Zeichen lang sein. Sie dürfen keine häufig genutzten Wörter (auch nicht in Kombination mit anderen Zeichen), wiederholten Zeichen, die eigene E-Mail-Adresse oder Tastaturfolgen enthalten. Der Login-Schutz erlaubt bis zu 20 Anmeldeversuche pro IP und Minute. Nach 5 fehlgeschlagenen Versuchen innerhalb von 15 Minuten wird die E-Mail-Adresse vorübergehend gesperrt. Nach erfolgreichem Login erhält jeder Nutzer ein 256-Bit-Token, mit dem er die Webseite ohne erneute Passwordeingabe nutzen kann. Das Token ist insgesamt 14 Tage und ohne Aktivität 72 Stunden gültig. Es wird ausschließlich in einem Browser-Cookie gespeichert, damit es bei XSS-Angriffen verborgen bleibt, und bei jeder Anmeldung neu erzeugt. Jeder Login sowie alle folgenden POST-, PATCH- und DELETE-Anfragen müssen das CSRF-Token enthalten, um vor CSRF-Angriffen zu schützen.

Datenzugriff. Jede Datenabfrage ist an den jeweiligen Nutzer gebunden. Versucht jemand, auf Daten anderer Personen zuzugreifen, erhält er immer „nicht gefunden“ als Antwort. Außerdem bekommen alle Ressourcen zufällige IDs statt fortlaufender Nummern.

Infrastruktur. Die App startet nicht, wenn die Produktionskonfiguration nicht korrekt eingestellt ist. Die Container laufen im Read-only-Modus mit eingeschränkten Benutzerrechten, und neue Privilegien sind nicht erlaubt. Zusätzlich schützen strenge HTTP-Security-Header sowie eine CSP- und CORS-Policy das System.

Unser Fazit: Die größten Risiken liegen weniger im Code als im Umgang mit den Aufnahmen. Einwilligung und Speicherung haben deshalb für die Weiterentwicklung die höchste Priorität.